

PHASE 6: EXTENSIONS (DEADLINE: **Follow Final Report Deadline**)

(SUBTOTAL: 9', BONUS: 7' MAX)

In this phase, you can choose any combinations of the following items to implement. At most 7' bonus will be awarded.

1. Mashup: Including a social plugin in the main page (e.g., Meta, [X](#), ...) _____/ 2'
 - o Meta: <https://developers.facebook.com/docs/plugins/>
2. SEO: Apply search engine optimized (or user-friendly) URLs when browsing products _____/ 4'
 - o Include the name of categories and products into the URLs:
e.g. <https://yourdomain.com/2-Fruits/> for browsing products under the category Fruits
e.g. [https:// yourdomain.com /2-Fruits/9-Apple](https://yourdomain.com/2-Fruits/9-Apple) for browsing product details
 - o You can map the above URLs to your Node using Apache scripts (Hint: google RedirectCond)
 - o Or handle it using Node param in path
 - o (Note) Full bonus will be obtained only if SEO can be automatically applied to all products, including ones newly inserted.
3. Supporting pagination/AJAX infinite scroll when browsing products in the main page _____/ 6'
4. Supporting HTML5 Drag-and-drop file selection in the admin panel _____/ 4'
 - o Create a dropping area that takes an image
 - o Display a thumbnail (i.e. smaller width and height) if the dropped file is an image; reject it otherwise
5. Supporting multi-session management _____/ 6'
 - o Show the simultaneous logged-in sessions in the admin panel
 - o Each session should be identified by an IP and allows logging out other sessions
 - o Hints: Use DB to save valid authentication token. Examples: Gmail and Dropbox
6. Supporting the use of gift vouchers (e.g. EASTER12 for \$5 discount) _____/ 8'
 - o Create a DB table called vouchers that store voucher code and the corresponding discount
 - The coupon should have a limited quota; and you should be aware of TOUTOC attack
 - o Add a field for voucher code just above the checkout button
 - Auto fill the voucher code if it is supplied through a query parameter (e.g. ?vcode=EASTER12)
 - o Use AJAX to dynamically validate the coupon code (using onkeydown/onblur handler)
 - o Apply discount and update the UI to reflect the discounted price and the discount amount
 - o Security: Make proper validations throughout the checkout process
 - o Hints: HTML variables in p. 433 of the first reference
7. Supporting Secure Authentication with OAuth or WebAuthn _____/ 9'
 - o Google: <http://code.google.com/apis/accounts/docs/OAuth2.html>
 - o Facebook: <https://developers.facebook.com/docs/authentication/>
 - o WebAuthn: <https://webauthn.io/>
8. Supporting secure password reset through email _____/ 6'
 - o A page that asks for email address for password recovery
 - o Only if the email corresponds to an existing user, an email will be generated
 - o In the email, a password recovery hyperlink will make use of a random nonce
 - o Only the user/admin receiving the nonce can reset his/her password
9. Secure 2FA for login _____/ 5'
 - o Implement an additional mechanism to password-based login
 - e.g., One-Time Pad, SMS or email verification or biometric information (via mobile).
10. A Complete Order management system for users (Phase 5 Requirement 7) _____/ 4'
 - o The user can view all his orders
 - o Let the user pay again, modify, and cancel any unpaid orders
11. Rating/Comment on complete order and products _____/ 12'
 - o When a user completes an order, he/she can leave a comment and rating within 7 days.
 - o If no rating/comment received, assume the product has the top rating (e.g., 10/10)
 - o The average rating will be displayed in the main page (showing products)
 - o The average rating and comments (top 5) will be displayed in the product detail page.
12. Supporting discounts when purchasing multiple quantities of a product type _____/ 9'
 - o Create a DB table called discounts that store conditions for applying discounts
 - Conditions could include: "buy 2 get 1" and "buy \$10@2, \$6@1"

- Refer to parknshop.com for reference and details
 - o Update the UI to reflect the discounted price whenever the quantity conditions are met
 - o Security: Make proper validations throughout the checkout process
13. Apart from Paypal/Stripe, there are many other payment approaches, like Alipay, WeChat Pay and so on. In this step, you will add a second payment approach to your website ____/ 9'
14. Design an online chatbox on your website, users can click on it and send comments/enquiries to the customer service. ____/ 9'
- o Users' comments should be recorded and displayed in the admin panel.
 - o The customer service should be **interactive**.
15. In Product Page, allow multiple images or videos to be shown in the area. ____/ 5'
- Allow users to slide/select/view different images (cf. Amazon, [pns](#))
 - Keyword: [Image Slider](#). You may use libraries like [SwiperJS](#).
16. TBD – May release more options upon students' requests
- o Student can demonstrate it in the Final Report

PHASE 7: PEER HACKING (8 May 6PM to 10 May)

(SUBTOTAL: 15', BONUS: 10' MAX)

It is critical to defend against potential attacks *before* they turn into reality when the website is open to the public. Students are to exercise *ethical hacking* in this phase. Be reminded to **backup everything** (code, conf files).

1. (Optional) Practice with the use of any automated vulnerability scanner on **YOUR WEBSITE** _____ / 0'
 - o Another target, e.g., OWASP Juice Shop (the demo site in the lecture note), DVWA, ...
 - o Use an automated vulnerability scanner (e.g., Snyk, Nikto, or others). Fix **your** vulnerabilities, if any.
 - o **Scan ONLY your own website** to see what common errors you could have made
 - o Note: Beware of exceeding the bandwidth quota so that you are charged

IF your website does not allow user registration, leave a visible user account with password at the FRONT PAGE
This Can be reported as (Bug)

This is a game to help you learn security practically, which starts on **8 May to 10 May**. Site owners should responsibly react to the incidents and fix the problems as soon as possible to mitigate future exploits. Each student is entitled to a base score of 15, while the highest score is 25. Students must report any issues **at the Microsoft Form with a Unique ID (posted in Blackboard): [IERG 4210/IEMS 5718 Bug Report Form – Fill out form](#)**

1. Perform manual ethical hacking for shops of your classmates _____ / 15'
 - o For a vulnerability in Student V's shop being reported by Student R1: R1 + 4'
 - Student R1 reports and clearly specifies the problems: V - 2'
 - **Only the first 5 (non-repeated) entries a student submits will be counted.** We will sort your records based on the time you submit. Cherish your chances and make sure the bug really exists.
 - When reporting, Student R1 MUST strictly follow the following format
 - Shop Name with vulnerability: e.g. s81
 - Your **random ID** assigned on Blackboard
 - Type of Vulnerability: Prefixed with [OWASP Vulnerability types](#), e.g. [XSS]
 - Content: Answer the Questions in the report link
 - Attach at least one screen capture(s) for a proof and to aid illustration (recommend to use "anonymous" image upload site with 1 month validity period, e.g., <https://postimages.org/>)
 - If a bug report is invalid:
 - To dispute a bug, student V must load his/her source code from eLearn and demonstrate it during Video Demo
 - Student V fixes the problem on or before **Submitting the Report**
 - Should point out the solutions in the report
 - **No marks** will be deducted
 - o **Repeated report on the same bug of the same site after 8PM (8 May) will not get any point**
 - o For a non-security related bug in Student V's shop being reported by Student R:

Please understand that some students might skip doing a part or two, regarding them as bugs to report are meaningless to the aim of this phase. So, unless your discovery is a kind of system flaw, otherwise, do not report it.

- The marks allocation is half of the security ones: R1 + 1'
- Each bug MUST be prefixed by the numbering of assignment requirements V -1'
 - Example number: [P4-1] stands for requirement 1 in phase 4
- The bug must be reproducible in both Firefox and Chrome

Each student can report **at most 3 non-security related bugs**

- o Availability checks by the automated bot
 - <https://monitor.ierg4210.iecuhk.cc/status/all> will report the availability of shops during the whole period
 - **Deduct 2 mark to the OVERALL score if not functioning for 1 day:** V -3' / day
 - Also, do not hide your website page intentionally
- o Student R causes a high volume of traffic on others' websites
 - Includes but not limited to launching automated scan, DoS, or DDoS
 - Please shut the service to avoid being charged and submit the access_log to us ASAP

This game is expected to be quite exciting! :) This is an internal ethical hacking exercise; hence, students whose websites are exploited or found vulnerable should not take it as offensive but as a good learning opportunity. Students should respect each other and be polite in any circumstances. In case of dispute, TA will be the final judge on the marking. Drastic circumstances (e.g. bullying) can result in penalties when the instructor deems it appropriate

Final Report (Deadline: **12 May. No Extension**)

You should **start to compose the final report after the Phase 5 deadline**, then **add the bonus part and security fixes** before the report due.

Students need to document the completion of all the **(key) features** below. **If you deviate "too much" from the specification for some requirements, you are advised to provide a valid explanation. (e.g., Payment Process)**

1. Phase 1. Showing your AWS/Azure/Cloud services dashboard that you have set up the VM, virtual networks, and firewalls correctly.
 - A. Show that your website is accessible via the given URL.
 - B. Show that the response header does not show the server language/version, and the direction index is disabled.
 - C. Explain your web server architecture, e.g., Nginx, Node, SQL Server.
2. Phase 2 (&4).
 - A. Show your main page with products and categories.
 - i. Display products under a specific category
 - ii. Products will have their detailed page.
 - iii. Explain the frontend rendering methods, e.g., dynamically update via JS or server-side rendering.
 - B. Admin can create/delete products and categories.
 - i. Automatic image resizing is performed. (Add a product with a large image, and show it under the detailed page)
 - ii. New Product/Category is shown in the website.
 - iii. **Show that your admin panel-related paths are authorized users only.** Try to access it without login/user login/admin login.
3. Phase 3. Shopping Cart is updated without a page load
 - A. Add products to the shopping cart, and hover over the cart to show the added item
 - B. Add quantity of a product, and the total price is updated without page load.
 - C. Decrease the quantity of a product to 0 and it should be removed from the cart
4. Phase 4. Authentication for Admin Panel
 - A. Show/Explain your XSS, CSRF, SQLi, session fixation, and other defense mechanisms.
 - B. Show that the user can register, change the password, and logout
5. Phase 5. Checkout Workflow
 - A. Perform a checkout on the products in the shopping cart.
 - B. Show that the admin can track orders in the admin panel. (Created but not verified; You may open another browser in Incognito mode and act as user)
 - C. An order can be verified after the user completes the payment.
 - D. User can check his/her last order(s); Admin can check all orders
6. Phase 6. Any extension you have implemented.
 - A. Explain what feature(s) you have added.
 - B. High level idea of how it is implemented. You may show some of your source code

7. Any Security vulnerability or bugs fixed.

FINAL Q&A (if applicable)

(SUBTOTAL: -90')

Question forms may include but not limited to

- Illustrate a piece of code in your assignment, what does it do and why did you write like this
- Show how you protect your website from a certain type of attack
- Delete a few lines of your code and ask you to recover it

SID: _____

TOTAL: _____ / 124 (+17 BONUS)